

Documentação da Rota de Configurações

Visão geral

A rota:

`/api/configuracoes`

é responsável por centralizar o gerenciamento da **conta tenant da ótica**, das **preferências operacionais da plataforma** e dos **usuários de acesso ao sistema**.

Ela atende exclusivamente ao **painel administrativo** e permite:

- Consultar os dados da conta;
- Consultar as configurações da plataforma;
- Listar os usuários vinculados à conta;
- Criar novos usuários `admin` ou `balcao`;
- Editar dados da ótica;
- Editar preferências da conta;
- Editar usuários do tipo `balcao`;
- Remover usuários do tipo `balcao`.

Administradores podem ser **visualizados**, mas não podem ser **editados** nem **removidos** por esta rota.

Arquivo

`src/app/api/configuracoes/route.js`

Regras gerais de acesso

Todas as operações da rota exigem:

1. Usuário autenticado;
2. Perfil existente na tabela `usuarios`;
3. Usuário com `status = ativo`;
4. Usuário com `role = admin`.

Caso qualquer uma dessas condições falhe, a rota bloqueia a operação.

Permissões

P	G	P	PUT c o n t a	PUT configur ações	PUT usuário	DELETE usuário
A	S	Si	Sim	Sim	Apenas usuário balcão	Apenas usuário balcão
B	N	N	Não	Não	Não	Não

Dependências importantes

A rota usa:

`createClient()`

de:

`@/lib/supabase/server`

para validar a sessão do usuário logado.

Também usa o cliente administrativo do Supabase com:

SUPABASE_SERVICE_ROLE_KEY=

para:

- Criar usuários de autenticação;
- Atualizar e-mail de login;
- Redefinir senha;
- Excluir login;
- Consultar e alterar dados administrativos com segurança.

Variáveis de ambiente necessárias

NEXT_PUBLIC_SUPABASE_URL=

SUPABASE_SERVICE_ROLE_KEY=

Estrutura geral da rota

A rota possui quatro métodos:

GET

POST

PUT

DELETE

1. GET /api/configuracoes

Finalidade

Carrega todos os dados necessários para montar a aba de Configurações no painel admin.

Retorna

- Dados da conta tenant;
- Preferências da conta;

- Usuários cadastrados na plataforma.

Consulta realizada

Conta

```
.from("contas")  
  
.select("*")  
  
.eq("id", profile.conta_id)  
  
.single()
```

Configurações

```
.from("configuracoes_conta")  
  
.select("*")  
  
.eq("conta_id", profile.conta_id)  
  
.maybeSingle()
```

Usuários

```
.from("usuarios")  
  
.select("*")  
  
.eq("conta_id", profile.conta_id)  
  
.order("created_at", { ascending: true })
```

Resposta de sucesso

```
{  
  
  "success": true,  
  
  "conta": {  
  
    "id": "uuid-da-conta",  
  
    "nome_fantasia": "Ótica Visão Clara",
```

```
"razao_social": "Visão Clara Comércio LTDA",
"cnnpj": "12.345.678/0001-90",
"telefone": "(32) 99999-9999",
"email": "contato@oticavisao.com",
"cep": "36300-000",
"rua": "Rua das Flores",
"numero": "120",
"bairro": "Centro",
"cidade": "São João del-Rei",
"estado": "MG"
},
"configuracoes": {
  "id": "uuid-da-configuracao",
  "conta_id": "uuid-da-conta",
  "prefixo_os": "OS",
  "proximo_numero_os": 25,
  "permitir_edicao_os_terminal": true,
  "permitir_alterar_status_os_terminal": true,
  "permitir_anexos_terminal": true,
  "exibir_valor_vendido_relatorio_vendedor": true,
  "exibir_comissao_relatorio_vendedor": true,
  "exigir_observacao_ao_cancelar_os": false,
  "moeda": "BRL",
  "fuso_horario": "America/Sao_Paulo"
},
"usuarios": [
  {
```

```
    "id": "uuid-admin",
    "conta_id": "uuid-da-conta",
    "nome_completo": "Maria Eduarda",
    "email": "admin@otica.com",
    "telefone": "(32) 99999-9999",
    "role": "admin",
    "cargo": "Administrador",
    "status": "ativo",
    "pode_editar": false,
    "pode_remover": false
  },
  {
    "id": "uuid-balcao",
    "conta_id": "uuid-da-conta",
    "nome_completo": "Balcão 1",
    "email": "balcao1@otica.com",
    "telefone": "(32) 98888-7777",
    "role": "balcao",
    "cargo": "Balcão 1",
    "status": "ativo",
    "pode_editar": true,
    "pode_remover": true
  }
]
```

Erros possíveis

401 Unauthorized

```
{  
  
  "error": "Usuário não autenticado."  
  
}
```

403 Forbidden

```
{  
  
  "error": "Apenas administradores podem acessar as configurações."  
  
}
```

404 Not Found

```
{  
  
  "error": "Perfil de usuário não encontrado."  
  
}
```

500 Internal Server Error

```
{  
  
  "error": "Não foi possível carregar os dados da conta."  
  
}
```

ou

```
{  
  
  "error": "Não foi possível carregar as preferências da conta."  
  
}
```

ou

```
{  
  
  "error": "Não foi possível carregar os usuários da plataforma."  
  
}
```

2. POST `/api/configuracoes`

Finalidade

Cria um novo usuário de acesso à plataforma.

A criação é feita em duas etapas:

1. Criação do login no Supabase Auth;
2. Criação do perfil correspondente na tabela `usuarios`.

Perfis permitidos

admin

balcao

Body

```
{  
  "nome_completo": "Balcão 1",  
  "email": "balcao1@otica.com",  
  "telefone": "(32) 99999-1111",  
  "image_url": "",  
  "role": "balcao",  
  "cargo": "Balcão 1",  
  "status": "ativo",  
  "password": "senha1234",  
  "confirmPassword": "senha1234"  
}
```

Validações

A rota exige:

- `nome_completo` preenchido;
 - `email` preenchido;
 - `role` válido;
 - `status` válido;
 - Senha com no mínimo 8 caracteres;
 - `password` e `confirmPassword` iguais;
 - E-mail ainda não existente na tabela `usuarios`.
-

Roles válidas

admin

balcao

Status válidos

ativo

inativo

bloqueado

Comportamento interno

Criação do usuário no Auth

```
admin.auth.admin.createUser({
```

```
  email,
```

```
  password,
```

```
  email_confirm: true,
```

```
  user_metadata: {
```

```
    nome_completo,
```

```
telefone,
```

```
role
```

```
}
```

```
})
```

Criação do perfil

```
.from("usuarios")
```

```
.insert({
```

```
id: authData.user.id,
```

```
conta_id: profile.conta_id,
```

```
nome_completo,
```

```
email,
```

```
telefone,
```

```
image_url,
```

```
role,
```

```
cargo,
```

```
status
```

```
})
```

```
.select("*")
```

```
.single()
```

Resposta de sucesso

```
{
```

```
"success": true,
```

```
"message": "Usuário criado com sucesso.",
```

```
"usuario": {
```

```
"id": "uuid-do-novo-usuario",
```

```
"conta_id": "uuid-da-conta",  
"nome_completo": "Balcão 1",  
"email": "balcao1@otica.com",  
"telefone": "(32) 99999-1111",  
"role": "balcao",  
"cargo": "Balcão 1",  
"status": "ativo",  
"pode_editar": true,  
"pode_remove": true  
}  
}
```

Erros possíveis

400 Bad Request

```
{  
  "error": "Informe o nome completo do usuário."  
}  
  
{  
  "error": "Informe o e-mail do usuário."  
}  
  
{  
  "error": "Perfil de acesso inválido."  
}  
  
{  
  "error": "Status de usuário inválido."  
}
```

```
{  
  "error": "A senha precisa ter pelo menos 8 caracteres."  
}
```

```
{  
  "error": "As senhas não coincidem."  
}
```

409 Conflict

```
{  
  "error": "Já existe um usuário cadastrado com este e-mail."  
}
```

500 Internal Server Error

```
{  
  "error": "Não foi possível criar o login do usuário."  
}
```

ou

```
{  
  "error": "Não foi possível salvar o perfil do novo usuário."  
}
```

3. PUT /api/configuracoes

Finalidade

O método **PUT** possui três modos de atualização, controlados pelo campo:

```
{  
  "tipo": "..."  
}
```

Tipos aceitos:

conta

configuracoes

usuario

3.1 PUT tipo **conta**

Finalidade

Atualiza os dados cadastrais da conta tenant, ou seja, os dados da ótica.

Body

```
{  
  "tipo": "conta",  
  "nome_fantasia": "Ótica Visão Clara",  
  "razao_social": "Visão Clara Comércio LTDA",  
  "cnpj": "12.345.678/0001-90",  
  "inscricao_estadual": "",  
  "telefone": "(32) 99999-9999",  
  "email": "contato@otica.com",  
  "cep": "36300-000",  
  "rua": "Rua das Flores",  
  "numero": "120",  
  "complemento": "Loja 1",  
  "bairro": "Centro",  
  "cidade": "São João del-Rei",  
  "estado": "MG",  
}
```

```
"pais": "Brasil",  
  
"observacoes": "Conta principal da rede."  
  
}
```

Validação principal

nome_fantasia é obrigatório

Resposta de sucesso

```
{  
  
  "success": true,  
  
  "message": "Dados da conta atualizados com sucesso.",  
  
  "conta": {  
  
    "id": "uuid-da-conta",  
  
    "nome_fantasia": "Ótica Visão Clara",  
  
    "telefone": "(32) 99999-9999",  
  
    "email": "contato@otica.com"  
  
  }  
  
}
```

Erros possíveis

```
{  
  
  "error": "Informe o nome fantasia da ótica."  
  
}  
  
{  
  
  "error": "Não foi possível atualizar os dados da conta."
```

```
}
```

3.2 PUT tipo **configuracoes**

Finalidade

Atualiza as preferências operacionais da plataforma.

Essas preferências controlam a geração de OS, permissões do terminal e exibição de relatórios.

Body

```
{  
  
  "tipo": "configuracoes",  
  
  "prefixo_os": "OS",  
  
  "proximo_numero_os": 25,  
  
  "permitir_edicao_os_terminal": true,  
  
  "permitir_alterar_status_os_terminal": true,  
  
  "permitir_anexos_terminal": true,  
  
  "exibir_valor_vendido_relatorio_vendedor": true,  
  
  "exibir_comissao_relatorio_vendedor": true,  
  
  "exigir_observacao_ao_cancelar_os": false,  
  
  "moeda": "BRL",  
  
  "fuso_horario": "America/Sao_Paulo"  
}
```

Comportamento interno

A rota usa:

```
.upsert()
```

em:

```
configuracoes_conta
```

com conflito em:

```
conta_id
```

Ou seja:

- Se a configuração já existe, ela é atualizada;
- Se ainda não existe, ela é criada.

Resposta de sucesso

```
{  
  "success": true,  
  "message": "Preferências da conta atualizadas com sucesso.",  
  "configuracoes": {  
    "conta_id": "uuid-da-conta",  
    "prefixo_os": "OS",  
    "proximo_numero_os": 25,  
    "permitir_edicao_os_terminal": true,  
    "permitir_alterar_status_os_terminal": true,  
    "permitir_anexos_terminal": true  
  }  
}
```

Erros possíveis

```
{  
  "error": "Não foi possível atualizar as preferências da conta."  
}
```



```
}
```

3.3 PUT tipo **usuario**

Finalidade

Atualiza usuários do tipo **balcao**.

Usuários **admin** podem ser consultados, mas não podem ser alterados.

Body

```
{  
  "tipo": "usuario",  
  "id": "uuid-do-usuario",  
  "nome_completo": "Balcão Principal",  
  "email": "balcao@otica.com",  
  "telefone": "(32) 99999-2222",  
  "image_url": "",  
  "cargo": "Balcão Principal",  
  "status": "ativo",  
  "password": "novaSenha123",  
  "confirmPassword": "novaSenha123"  
}
```

Regras

- **id** obrigatório;
- Usuário precisa pertencer à mesma **conta_id** do admin logado;
- Usuário **admin** não pode ser editado;

- `nome_completo` obrigatório;
 - `email` obrigatório;
 - `status` precisa ser válido;
 - Senha só é alterada se enviada;
 - Quando houver nova senha:
 - mínimo de 8 caracteres;
 - confirmação obrigatória;
 - senhas precisam coincidir;
 - Se o e-mail mudar, o e-mail de autenticação também é atualizado.
-

Status válidos

ativo

inativo

bloqueado

Resposta de sucesso

```
{  
  "success": true,  
  "message": "Usuário atualizado com sucesso.",  
  "usuario": {  
    "id": "uuid-do-usuario",  
    "nome_completo": "Balcão Principal",  
    "email": "balcao@otica.com",  
    "telefone": "(32) 99999-2222",  
    "cargo": "Balcão Principal",  
    "status": "ativo",  
    "role": "balcao",  
    "pode_editar": true,  
    "pode_remover": true
```

```
}
```

```
}
```

Erros possíveis

```
{
```

```
  "error": "Informe o ID do usuário."
```

```
}
```

```
{
```

```
  "error": "Usuário não encontrado."
```

```
}
```

```
{
```

```
  "error": "Usuários administradores podem ser visualizados, mas não editados."
```

```
}
```

```
{
```

```
  "error": "Informe o nome completo do usuário."
```

```
}
```

```
{
```

```
  "error": "Informe o e-mail do usuário."
```

```
}
```

```
{
```

```
  "error": "Status de usuário inválido."
```

```
}
```

```
{
```

```
  "error": "A nova senha precisa ter pelo menos 8 caracteres."
```

```
}
```

```
{
```

```
"error": "As senhas não coincidem."
}

{
  "error": "Não foi possível atualizar a senha do usuário."
}

{
  "error": "Não foi possível atualizar o e-mail de login."
}

{
  "error": "Não foi possível atualizar o usuário."
}
```

4. DELETE /api/configuracoes

Finalidade

Remove um usuário do tipo `balcao`.

A remoção apaga:

1. O usuário do Supabase Auth;
2. O perfil da tabela `usuarios`, caso haja `ON DELETE CASCADE` configurado no banco.

Body

```
{
  "id": "uuid-do-usuario"
}
```

Regras

- `id` obrigatório;
 - Usuário precisa pertencer à conta do admin logado;
 - Usuário `admin` não pode ser removido;
 - Apenas usuários `balcao` podem ser excluídos.
-

Resposta de sucesso

```
{  
  
  "success": true,  
  
  "message": "Usuário removido com sucesso.",  
  
  "id": "uuid-do-usuario"  
}
```

Erros possíveis

```
{  
  
  "error": "Informe o ID do usuário."  
  
}  
  
{  
  
  "error": "Usuário não encontrado."  
  
}  
  
{  
  
  "error": "Usuários administradores podem ser visualizados, mas não removidos."  
  
}  
  
{  
  
  "error": "Não foi possível remover o usuário."  
  
}
```

Resumo rápido dos métodos

Método	Finalidade
GET	Carregar conta, configurações e usuários
POST	Criar novo usuário da plataforma
PUT <code>conta</code>	Atualizar dados da ótica
PUT <code>configuracoes</code>	Atualizar preferências
PUT <code>usuario</code>	Editar usuário balcão
DELETE	Remover usuário balcão

Contrato usado pelo front-end

Carregar aba

```
fetch("/api/configuracoes", {  
  method: "GET",  
  cache: "no-store",  
});
```

Criar usuário

```
fetch("/api/configuracoes", {  
  method: "POST",  
  headers: {  
    "Content-Type": "application/json",  
  },  
  body: JSON.stringify(payload),  
});
```

Atualizar conta

```
fetch("/api/configuracoes", {  
  method: "PUT",  
  headers: {  
    "Content-Type": "application/json",  
  },  
  body: JSON.stringify({  
    tipo: "conta",  
    ...payload,  
  }),  
});
```

Atualizar configurações

```
fetch("/api/configuracoes", {  
  method: "PUT",  
  headers: {  
    "Content-Type": "application/json",
```

```
},  
  
body: JSON.stringify({  
  tipo: "configuracoes",  
  ...payload,  
}),  
});
```

Atualizar usuário

```
fetch("/api/configuracoes", {  
  method: "PUT",  
  headers: {  
    "Content-Type": "application/json",  
  },  
  body: JSON.stringify({  
    tipo: "usuario",  
    ...payload,  
  }),  
});
```

Remover usuário

```
fetch("/api/configuracoes", {  
  method: "DELETE",  
  headers: {  
    "Content-Type": "application/json",  
  },  
  body: JSON.stringify({
```



```
id: usuario.id,  
  
}),  
  
});
```

Observações de arquitetura

A rota foi construída seguindo três princípios importantes:

1. Payload completo

O front envia o objeto inteiro, e a API normaliza e persiste o necessário. Isso evita ficar ajustando dezenas de campos em vários arquivos conforme o sistema cresce.

2. Segurança no backend

O front mostra ou oculta botões, mas **quem realmente decide é a API**.

Mesmo que alguém tente forçar uma requisição manual:

- Balcão não acessa a rota;
- Admin não consegue editar outro admin;
- Admin não consegue remover outro admin;
- Usuários de outra conta não são alterados.

3. Filtros no front

A rota retorna os dados da conta com `select("*")`, e a filtragem de usuários fica no front-end, deixando a tela mais rápida e o backend mais simples.

-